Scan Report

Web Application Vulnerability Scan Report
Scan ID: 16
Target: OWASP Juice Shop Project (http://juice-shop:3000)
Scan type: ZAP_PASSIVE | Status: COMPLETED
Native engine: COMPLETED | OWASP ZAP: COMPLETED | NVD lookup: NOT_REQUESTED
Scope counts: 1 discovered, 1 visited, 1 passively tested; 1 persisted HTML crawl records.
Discovered is bounded same-origin link discovery; visited is successfully fetched pages; passive
ly tested counts pages checked by native passive response checks.
Severity totals: High 0, Medium 5, Low 10, Total 15
Checks in scope: Native passive response checks; OWASP ZAP spider and passive analysis
Checks out of scope: Native SQL injection and reflected XSS active probes; OWASP ZAP active scan
ning; Authorization and access-control testing
Status details: Native and OWASP ZAP scans completed successfully
Findings:
[LOW] INFORMATION_DISCLOSURE_SERVER (finding 81)
Affected location: http://juice-shop:3000/
Evidence: squid/6.13
Rationale: The web/application server is leaking version information via the "Server" HTTP respo
nse header. Access to such information may facilitate attackers identifying other vulnerabilitie
s your web/application server is subject to.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10036 | Confidence High | CWE 497 | WASC 13 | Reference https://httpd.apac
he.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versio
ns/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured
to suppress the "Server" header or provide generic details.
[LOW] ZAP_INFORMATION_DISCLOSURE_SUSPICIOUS_COMMENTS (finding 80)
Affected location: http://juice-shop:3000/
Evidence: from
Rationale: The response appears to contain suspicious comments which may help an attacker.
Detection source: OWASP_ZAP | Assessment status: POTENTIAL
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10027 | Confidence Medium | CWE 615 | WASC 13 | Reference
Remediation: Remove all comments that return information that may help an attacker and fix any u
nderlying problems they refer to.
[MEDIUM] MISSING_CONTENT_SECURITY_POLICY (finding 79)
Affected location: http://juice-shop:3000/
Evidence: Content Security Policy (CSP) Header Not Set
Rationale: Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attac
ks. These attacks are used for everything from data theft to site defacement or distribution of
malware. CSP provides a set of standard HTTP headers that allow website owners to declare approv
ed sources of content that browsers should be allowed to load on that page \u{2014} covered type
s are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, A
ctiveX, audio and video files.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10038 | Confidence High | CWE 693 | WASC 15 | Reference https://developer.
mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Conten
t_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-cs
p/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-
security-policy.com/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured

Scan Report (continued)

to set the Content-Security-Policy header.
[LOW] INFORMATION_DISCLOSURE_SERVER (finding 78)
Affected location: http://juice-shop:3000/robots.txt
Evidence: squid/6.13
Rationale: The web/application server is leaking version information via the "Server" HTTP respo
nse header. Access to such information may facilitate attackers identifying other vulnerabilitie
s your web/application server is subject to.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10036 | Confidence High | CWE 497 | WASC 13 | Reference https://httpd.apac
he.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versio
ns/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured
to suppress the "Server" header or provide generic details.
[LOW] INFORMATION_DISCLOSURE_SERVER (finding 77)
Affected location: http://juice-shop:3000
Evidence: squid/6.13
Rationale: The web/application server is leaking version information via the "Server" HTTP respo
nse header. Access to such information may facilitate attackers identifying other vulnerabilitie
s your web/application server is subject to.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10036 | Confidence High | CWE 497 | WASC 13 | Reference https://httpd.apac
he.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versio
ns/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured
to suppress the "Server" header or provide generic details.
[LOW] INFORMATION_DISCLOSURE_SERVER (finding 76)
Affected location: http://juice-shop:3000/sitemap.xml
Evidence: squid/6.13
Rationale: The web/application server is leaking version information via the "Server" HTTP respo
nse header. Access to such information may facilitate attackers identifying other vulnerabilitie
s your web/application server is subject to.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10036 | Confidence High | CWE 497 | WASC 13 | Reference https://httpd.apac
he.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versio
ns/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured
to suppress the "Server" header or provide generic details.
[LOW] ZAP_INFORMATION_DISCLOSURE_SUSPICIOUS_COMMENTS (finding 75)
Affected location: http://juice-shop:3000
Evidence: from
Rationale: The response appears to contain suspicious comments which may help an attacker.
Detection source: OWASP_ZAP | Assessment status: POTENTIAL
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10027 | Confidence Medium | CWE 615 | WASC 13 | Reference
Remediation: Remove all comments that return information that may help an attacker and fix any u
nderlying problems they refer to.
[LOW] ZAP_INFORMATION_DISCLOSURE_SUSPICIOUS_COMMENTS (finding 74)
Affected location: http://juice-shop:3000/sitemap.xml
Evidence: from
Rationale: The response appears to contain suspicious comments which may help an attacker.
Detection source: OWASP_ZAP | Assessment status: POTENTIAL

Scan Report (continued)

Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10027 | Confidence Medium | CWE 615 | WASC 13 | Reference
Remediation: Remove all comments that return information that may help an attacker and fix any u
nderlying problems they refer to.
[LOW] ZAP_INFORMATION_DISCLOSURE_SUSPICIOUS_COMMENTS (finding 73)
Affected location: http://juice-shop:3000/robots.txt
Evidence: from
Rationale: The response appears to contain suspicious comments which may help an attacker.
Detection source: OWASP_ZAP | Assessment status: POTENTIAL
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10027 | Confidence Medium | CWE 615 | WASC 13 | Reference
Remediation: Remove all comments that return information that may help an attacker and fix any u
nderlying problems they refer to.
[MEDIUM] MISSING_CONTENT_SECURITY_POLICY (finding 72)
Affected location: http://juice-shop:3000/robots.txt
Evidence: Content Security Policy (CSP) Header Not Set
Rationale: Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attac
ks. These attacks are used for everything from data theft to site defacement or distribution of
malware. CSP provides a set of standard HTTP headers that allow website owners to declare approv
ed sources of content that browsers should be allowed to load on that page \u{2014} covered type
s are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, A
ctiveX, audio and video files.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10038 | Confidence High | CWE 693 | WASC 15 | Reference https://developer.
mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Conten
t_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-cs
p/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-
security-policy.com/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured
to set the Content-Security-Policy header.
[MEDIUM] MISSING_CONTENT_SECURITY_POLICY (finding 71)
Affected location: http://juice-shop:3000/sitemap.xml
Evidence: Content Security Policy (CSP) Header Not Set
Rationale: Content Security Policy (CSP) is an added layer of security that helps to detect and
mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attac
ks. These attacks are used for everything from data theft to site defacement or distribution of
malware. CSP provides a set of standard HTTP headers that allow website owners to declare approv
ed sources of content that browsers should be allowed to load on that page \u{2014} covered type
s are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, A
ctiveX, audio and video files.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10038 | Confidence High | CWE 693 | WASC 15 | Reference https://developer.
mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Conten
t_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-cs
p/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-
security-policy.com/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured
to set the Content-Security-Policy header.
[MEDIUM] MISSING_CONTENT_SECURITY_POLICY (finding 70)
Affected location: http://juice-shop:3000
Evidence: Content Security Policy (CSP) Header Not Set

Scan Report (continued)

Rationale: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attac ks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approv ed sources of content that browsers should be allowed to load on that page \u{2014} covered type s are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, A ctiveX, audio and video files.
Detection source: OWASP_ZAP | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule 10038 | Confidence High | CWE 693 | WASC 15 | Reference https://developer. mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Conten t_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-cs p/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
Remediation: Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
[LOW] MISSING_PERMISSIONS_POLICY (finding 69)
Affected location: http://juice-shop:3000 [Permissions-Policy]
Evidence: Permissions-Policy is absent
Rationale: Observed in the target HTTP response
Detection source: PASSIVE_HEADERS | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule null | Confidence null | CWE null | WASC null | Reference null
Remediation: Restrict unnecessary browser capabilities with Permissions-Policy.
[LOW] MISSING_REFERRER_POLICY (finding 68)
Affected location: http://juice-shop:3000 [Referrer-Policy]
Evidence: Referrer-Policy is absent
Rationale: Observed in the target HTTP response
Detection source: PASSIVE_HEADERS | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule null | Confidence null | CWE null | WASC null | Reference null
Remediation: Set an explicit Referrer-Policy appropriate for the application.
[MEDIUM] MISSING_CONTENT_SECURITY_POLICY (finding 67)
Affected location: http://juice-shop:3000 [Content-Security-Policy]
Evidence: Content-Security-Policy is absent
Rationale: Observed in the target HTTP response
Detection source: PASSIVE_HEADERS | Assessment status: OBSERVED
Assessment note: Automated status does not independently confirm exploitability.
Source metadata: Rule null | Confidence null | CWE null | WASC null | Reference null
Remediation: Add a restrictive Content-Security-Policy.